🔴 Red Team Rules of Engagement (RoE)

Cybersecurity Lab Assessment.

1️⃣🎯 Engagement Overview:

This document defines the **Rules of Engagement (RoE)** for the **mock Red Team security assessment** conducted within a **controlled cybersecurity lab environment**.

The purpose of this engagement is to **simulate real-world adversarial attack techniques** in order to:

🔍 Identify system vulnerabilities
⚠️ Validate exploitability of discovered weaknesses
📊 Document security risks and exposure levels
🛡️ Improve defensive security awareness

All testing activities will follow **ethical penetration testing practices** and must remain strictly **within the authorized boundaries defined in this document**.

2️⃣📌 Scope of Engagement:

The scope of this **Red Team assessment** is **strictly limited** to a **single vulnerable virtual machine** operating inside an **isolated cybersecurity lab environment**.

🖥️ Authorized Target System

Target	Description	Environment

Metasploitable2 VM	Intentionally vulnerable Linux system designed for penetration testing practice	Isolated Virtual Lab

🌐 Network Scope:

Testing is restricted to the **internal lab network only**.

✔ Internal cybersecurity lab network
✔ Authorized target machine only

❌ External internet targets
❌ Any production systems
❌ Additional virtual machines not listed in scope

🚨 **Any activity outside this defined scope is strictly prohibited.**

3️⃣ ⚔️ Authorized Activities:

The **Red Team** is authorized to perform the following **controlled security testing activities** during the engagement period.

3.1 🔍 Reconnaissance.

Initial **information gathering** activities to identify accessible systems and services.

Examples include:

- 🌐 Network discovery
- 🖥️ Host identification
- 🔎 Service enumeration

3.2 📡 Network Scanning.

Security scanning tools may be used to identify **open ports, active services, and exposed attack surfaces**.

Examples:

- 🛰️ Nmap scanning
- 🔎 Service fingerprinting
- 🔢 Port enumeration

3.3 ⚠️ Vulnerability Scanning.

Automated vulnerability scanners may be used to identify **known security weaknesses** within the target system.

Examples:

- 🛠️ OpenVAS vulnerability scanning
- 📚 Identification of known CVEs
- 📊 Risk classification using CVSS scores

3.4 💥 Controlled Exploitation.

The Red Team may attempt to **exploit identified vulnerabilities** to simulate **real-world attacker techniques**.

Examples:

- ⚙️ Using Metasploit exploit modules
- 🐚 Executing payloads to obtain system access
- 🔓 Demonstrating vulnerability impact

⚠️ **All exploitation must remain controlled, safe, and reversible.**

3.5 🧠 Post-Exploitation Testing.

After successful exploitation, limited **post-exploitation activities** may be conducted to evaluate **attacker capabilities**.

Examples:

- 🐚 Establishing a shell session
- 🔐 Privilege enumeration
- 📋 System information gathering
- 📍 Demonstrating persistence techniques

3.6 📝 Documentation and Reporting.

All activities must be **carefully documented** for reporting and analysis.

Required documentation includes:

📸 Screenshots of tools used
📊 Exploit execution results
⚠️ Vulnerability findings
🧾 Security risk analysis

This documentation will support the **final Red Team assessment report**.

4️⃣🚫 Prohibited Activities:

The following activities are **strictly forbidden** to ensure **system stability, safety, and ethical compliance**.

4.1 🧨 Data Destruction.

The Red Team **must not delete, modify, corrupt, or destroy** any files on the target system.

4.2 🌍 Attacks Outside the Lab Network.

Testing must **not target**:

❌ External networks
❌ Internet-connected systems
❌ Other virtual machines outside scope

4.3 💣 Denial of Service (DoS).

The following **disruptive attacks are prohibited**:

🚫 DoS attacks
🚫 Resource exhaustion attacks
🚫 Service crashing attempts

4.4 🔐 Unauthorized Access

Accessing **systems outside the defined engagement scope** is **not permitted** under any circumstances.

🚨 If accidental access occurs:

1️⃣ Stop testing immediately
2️⃣ Document the incident
3️⃣ Report the issue to the engagement supervisor

5️⃣ 🗓️ Engagement Timeline:

The Red Team assessment will be conducted within the following **defined testing window**.

Phase	Timeline
🚀 Engagement Start	Monday

⚔️ Security Testing	One week
📝 Final Documentation	Thursday
📤 Submission Deadline	Friday, 13 March - 5:00PM

⚠️ **All activities must be completed before the submission deadline.**

6️⃣ 🎯 Engagement Objective:

The primary objective of this Red Team exercise is to **simulate realistic cyber-attack scenarios** in order to improve **defensive security awareness and incident preparedness**.

Key goals include:

🔍 Identifying vulnerabilities within the target system
💥 Demonstrating exploitability of discovered weaknesses
🧠 Assessing attacker capabilities after compromise
⚠️ Documenting security risks and potential impact
🛡️ Providing structured recommendations for security improvement

This exercise supports the development of **practical offensive security skills** and **defensive cybersecurity awareness**.

7️⃣ ⚖️ Ethical and Legal Compliance:

All Red Team activities must adhere to **ethical cybersecurity standards and responsible security testing practices**.

Key Principles:

✔ Operate strictly within the defined scope
✔ Avoid system damage or service disruption
✔ Maintain confidentiality of lab systems
✔ Transparently document all testing activities

🔐 Ethical hacking principles must guide **every stage of the engagement**.

8️⃣📊 Conclusion:

This **Rules of Engagement (RoE)** document establishes **clear operational boundaries** for the Red Team security assessment.

By defining:

📌 Scope of testing
⚔️ Authorized activities
🚫 Prohibited actions
🗓️ Timeline
🎯 Engagement objectives

the assessment ensures that all testing remains:

✔ Controlled
✔ Ethical
✔ Secure
✔ Focused on improving cybersecurity awareness

The engagement ultimately contributes to **stronger defensive security practices and improved vulnerability management**.

🛡️ MITRE ATT&CK Mapping

📌 50-Word MITRE ATT&CK Mapping Summary:

The **MITRE ATT&CK Framework** mapping for this assessment corresponds to 🎯 **Technique T1059 – Command and Scripting Interpreter**.

During the exploitation phase, the **Metasploit Framework** was used to exploit the **VSFTPD backdoor vulnerability**, resulting in a 💻 **remote shell session** on the compromised host.

This access enabled ⚡ **command execution**, 🔍 **system interaction**, and 🧠 **further post-exploitation activities**, demonstrating how attackers can 🚨 **gain control, execute commands, and escalate their foothold** within a vulnerable system.